รายงานผลการทดสอบเจาะระบบ (Penetration Testing Report)

โครงการ (Project): Example Project

เจ้าของโครงการ (Project Owner): Crafto Co. Ltd.

หมายเลขเอกสาร (Job ID): JOB-001

วันที่ทดสอบ: 01/01/2026 – 05/01/2026

จัดเตรียมโดย: My Security Scanner

อีเมลสนับสนุน: support@example.com

สารบัญ

1. บทสรุปผู้บริหาร (Executive Summary) 3
1.1. วัตถุประสงค์และภาพรวมการดำเนินงาน 3
1.2. สรุปผลการตรวจพบช่องโหว่ 3
1.3. Vulnerability Dashboard 3
1.4. สรุปผลการประเมินรายสินทรัพย์ 3
1.5. ข้อเสนอแนะเชิงกลยุทธ์สำหรับผู้บริหาร 3
2. ขอบเขตการดำเนินงาน (Scope of Work) 4
2.1. ขอบเขตของสินทรัพย์ที่ทำการตรวจสอบ 4
2.2. สถาปัตยกรรมการทดสอบและเทคโนโลยีที่ใช้ 4
2.3. ขั้นตอนการทดสอบด้วยระบบอัตโนมัติ 4
3. รายละเอียดผลการทดสอบเจาะระบบ (Technical Findings) 5
3.1. รูปแบบการนำเสนอรายงานผลการตรวจพบ 5
3.2. รายละเอียดช่องโหว่ 5
4. สถานะการจัดการช่องโหว่ (Vulnerability Lifecycle Tracking) 8
4.1. นิยามสถานะการดำเนินงาน 8
5. บทสรุปและข้อเสนอแนะ (Conclusion and Recommendations) 9
5.1. บทสรุปภาพรวมความปลอดภัย 9
5.2. การประเมินประสิทธิภาพของระบบ Security Worker 9
5.3. ข้อเสนอแนะเพื่อการปรับปรุง 9
ผ1. ภาคผนวก 1: รายละเอียดวิธีการและขั้นตอนการตรวจประเมิน 10
ผ2. ภาคผนวก 2: เกณฑ์การประเมินระดับความเสี่ยง (Risk Rating) 11

1. บทสรุปผู้บริหาร (Executive Summary)

1.1. วัตถุประสงค์และภาพรวมการดำเนินงาน (Project Objective & Overview)

การทดสอบเจาะระบบ (Penetration Testing) สำหรับโครงการ **Example Project** มีวัตถุประสงค์หลักเพื่อประเมินระดับความมั่นคงปลอดภัยและค้นหาช่องโหว่เชิงรุก โดยอาศัยเทคโนโลยีการตรวจสอบอัตโนมัติจากระบบ **My Security Scanner** ดำเนินการในรูปแบบ Gray Box Testing

1.2. สรุปผลการตรวจพบช่องโหว่ (Vulnerability Summary)

ระบบตรวจพบช่องโหว่จำนวนรวมทั้งหมด **0** รายการ จากสินทรัพย์ทั้งหมด **0** รายการ

- Critical (วิกฤต): **0** รายการ
- High (สูง): **0** รายการ
- Medium (กลาง): **0** รายการ
- Low (ต่ำ): **0** รายการ

1.3. Vulnerability Dashboard

[กราฟสรุปช่องโหว่ — placeholder]

1.4. สรุปผลการประเมินรายสินทรัพย์ (Asset-Based Risk Summary)

Asset ID	ชื่อสินทรัพย์	IP/URL	ช่องโหว่ความรุนแรงสูง	Status
AS-001	example.com	https://example.com	0	Open
AS-002	api.example.com	https://api.example.com	0	Open
AS-003	192.168.1.10	http://192.168.1.10	0	Mitigated

1.5. ข้อเสนอแนะเชิงกลยุทธ์สำหรับผู้บริหาร (Management Recommendations)

- **ระยะสั้น:** มอบหมายผู้รับผิดชอบแก้ไขช่องโหว่ระดับวิกฤตและสูง พร้อมทำการทดสอบซ้ำ (Re-testing)
- **ระยะกลาง:** บูรณาการระบบตรวจสอบความปลอดภัยอัตโนมัติเข้ากับวงจรการพัฒนา (DevSecOps)
- **ระยะยาว:** พัฒนาทักษะบุคลากรด้าน Security Coding ตามมาตรฐาน ISO/IEC 27001 หรือ NIST Framework

2. ขอบเขตและระเบียบวิธีการปฏิบัติงาน (Scope and Methodology)

2.1. ขอบเขตของสินทรัพย์ที่ทำการตรวจสอบ (Audit Scope)

ลำดับที่	ชื่อระบบ	รายละเอียด	IP / URL เป้าหมาย
1	example.com	Main production website.	https://example.com
2	api.example.com	Public API server.	https://api.example.com
3	192.168.1.10	Internal admin panel.	http://192.168.1.10

2.2. สถาปัตยกรรมการทดสอบและเทคโนโลยีที่ใช้ (Technical Architecture)

1. **Asset Configuration:** ระบุเป้าหมายและขอบเขตผ่าน Centralized Management Website
2. **Worker Deployment:** ติดตั้ง Security Worker ลงใน Dedicated Pentest Machine
3. **Autonomous Execution:** สแกนแบบ Fully Automated ตั้งแต่ Endpoint Discovery จนถึงการวิเคราะห์ช่องโหว่

2.3. ขั้นตอนการทดสอบด้วยระบบอัตโนมัติ (Automated Testing Process)

- **Stateful Discovery:** Browser Automation จัดการ Session และข้ามระบบยืนยันตัวตนได้อัตโนมัติ
- **Dynamic Traffic Interception:** ดักจับ XHR/Fetch เพื่อค้นหา Hidden API Endpoints
- **Intelligent Payload Injection:** Context Analysis เพื่อเลือก Payloads ที่เหมาะสม
- **PoC Generation:** บันทึก Visual Evidence และ cURL Command อัตโนมัติ

3. รายละเอียดผลการทดสอบทางเทคนิค (Technical Findings)

3.1. รูปแบบการนำเสนอรายงานผลการตรวจพบ

- **Technical Evidence:** Payload, cURL และภาพถ่ายหน้าจอเพื่อใช้ใน Replication
- **Accountability & Workflow:** Assigned To และ Verified By เพื่อความโปร่งใสใน Remediation Lifecycle

3.2. รายละเอียดช่องโหว่

รายละเอียดช่องโหว่หมายเลข: V-001

[General Information]

- ประเภทช่องโหว่: SQL Injection
- Severity: **Critical** | CVSS v3.1: **9.8**
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Status: Open

[Administrative Details]

- Assigned To: John Doe
- Verified By: Jane Smith
- Related Asset: example.com

[Technical Context]

- Location: https://example.com/login
- Parameter: username
- Description: SQL Injection vulnerability detected.

[Proof of Concept]

- Payload: `' OR '1'='1`
- cURL: `curl -X POST https://example.com/login`
- Evidence:

[ไม่มีภาพหลักฐาน]

[Recommendation]

- Use parameterized queries.

รายละเอียดช่องโหว่หมายเลข: V-002

[General Information]

- ประเภทช่องโหว่: Broken Access Control
- Severity: **High** | CVSS v3.1: **8.2**
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
- Status: Open

[Administrative Details]

- Assigned To: Alice
- Verified By: Bob
- Related Asset: api.example.com

[Technical Context]

- Location: https://api.example.com/admin
- Parameter: N/A
- Description: Unauthorized access to admin endpoint.

[Proof of Concept]

- Payload: `Direct URL access`
- cURL: `curl https://api.example.com/admin`
- Evidence:

[ไม่มีภาพหลักฐาน]

[Recommendation]

- Implement role-based access control.

รายละเอียดช่องโหว่หมายเลข: V-003

[General Information]

- ประเภทช่องโหว่: Cross-Site Scripting (XSS)
- Severity: **Medium** | CVSS v3.1: **6.5**
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
- Status: Mitigated

[Administrative Details]

- Assigned To: Charlie
- Verified By: Jane Smith
- Related Asset: 192.168.1.10

[Technical Context]

- Location: http://192.168.1.10/profile
- Parameter: name
- Description: Reflected XSS vulnerability.

[Proof of Concept]

- Payload:
- cURL: `curl http://192.168.1.10/profile?name=test`
- Evidence:

[ไม่มีภาพหลักฐาน]

[Recommendation]

- Sanitize user input.

4. สถานะและวงจรการจัดการช่องโหว่ (Vulnerability Lifecycle Tracking)

Vuln ID	Vuln Type	Target	Assigned To	Verified By	Status
V-001	SQL Injection	example.com	John Doe	Jane Smith	Open
V-002	Broken Access Control	api.example.com	Alice	Bob	Open
V-003	Cross-Site Scripting (XSS)	192.168.1.10	Charlie	Jane Smith	Mitigated

4.1. นิยามสถานะการดำเนินงาน (Status Definition)

- **Open:** ช่องโหว่ได้รับการยืนยันและบันทึกเข้าสู่ฐานข้อมูลแล้ว รอการวิเคราะห์และมอบหมาย
- **In Progress:** มอบหมายไปยัง Developer แล้ว อยู่ในขั้นตอนการแก้ไข
- **Fixed / Pending Verification:** แก้ไขเสร็จสิ้น รอ Pen Tester ทดสอบซ้ำ (Re-testing)
- **Mitigated:** ดำเนินการบรรเทาความเสี่ยงเบื้องต้นแล้ว

5. บทสรุปและข้อเสนอแนะ (Conclusion and Recommendations)

5.1. บทสรุปภาพรวมความปลอดภัย (Overall Security Conclusion)

จากการทดสอบเจาะระบบภายใต้โครงการ **Example Project** โดยใช้ระบบ **My Security Scanner** พบช่องโหว่รวม **0** รายการ ซึ่งหากไม่ได้รับการแก้ไขอาจส่งผลกระทบต่อ Confidentiality และ Integrity ของข้อมูลในระดับองค์กร

5.2. การประเมินประสิทธิภาพของระบบ Security Worker

- **Deep Visibility:** ตรวจพบ Shadow API ผ่าน Traffic Interception
- **Accuracy & Reliability:** Dynamic Verification ลด False Positive ได้อย่างมีนัยสำคัญ
- **Documentation Speed:** จัดทำ PoC ได้ทันที ช่วยลดเวลาทำรายงานถึง 72.41%

5.3. ข้อเสนอแนะเพื่อการปรับปรุง (Strategic Recommendations)

- **Remediation Priority:** เร่งแก้ไข Critical และ High ทั้งหมด พร้อม Re-testing
- **Integration with DevSecOps:** บูรณาการ Security Worker เข้า CI/CD Pipeline
- **Security Training:** ส่งเสริม Secure Coding ตามมาตรฐาน OWASP

ภาคผนวก 1: รายละเอียดวิธีการและขั้นตอนการตรวจประเมิน

อ้างอิงตามมาตรฐานสากล OWASP Top 10:2021 และ NIST SP 800-115

1. การรวบรวมข้อมูล (Information Gathering)

- **Active Reconnaissance:** Browser Automation สำรวจโครงสร้างเว็บแอปพลิเคชัน
- **Network Traffic Interception:** Playwright ดักจับ XHR/Fetch เพื่อค้นหา API Endpoint
- **DNS & Service Discovery:** ตรวจสอบ DNS และหมายเลขไอพีเพื่อกำหนดขอบเขต

2. การระบุและวิเคราะห์ช่องโหว่ (Vulnerability Identification)

- **Monkey Patching Technology:** สอดแทรก Probes เข้าไปใน Browser Runtime
- **Context-Aware Fuzzing:** วิเคราะห์บริบทพารามิเตอร์ก่อนส่ง Probe Strings
- **Vulnerability Library Matching:** เปรียบเทียบกับคลังข้อมูลมาตรฐาน (SQLi, XSS, Path Traversal)

3. การทดสอบการบุกรุกเพื่อยืนยันผล (Exploitation & Verification)

- **Dynamic Payload Injection:** ส่ง Non-destructive Payloads เพื่อยืนยันช่องโหว่
- **Automated Confirmation Signal:** รอรับสัญญาณยืนยัน เช่น XSS_CONFIRMED
- **Access Control Testing:** ทดสอบ Privilege Escalation ด้วยสิทธิ์จำกัด

4. การวิเคราะห์ผลและจัดทำรายงาน (Analysis & Documentation)

- **Evidence Collection:** บันทึกภาพหน้าจอและ cURL อัตโนมัติ
- **Vulnerability Lifecycle Mapping:** นำข้อมูลเข้าระบบ Assign และเตรียม Re-test

ภาคผนวก 2: เกณฑ์การประเมินระดับความเสี่ยง (Risk Rating)

1. OWASP Risk Rating

ความเสี่ยง (Risk) = ความเป็นไปได้ (Likelihood) × ผลกระทบ (Impact)

1.1. ตัวแปรที่ใช้ในการคำนวณ

- **Threat Agent Factors:** Skill Level, Motive, Size
- **Vulnerability Factors:** Ease of discovery, Ease of exploit, Awareness, Intrusion detection
- **Technical Impact:** Confidentiality, Integrity, Availability, Accountability
- **Business Impact:** Financial, Reputation, Compliance, Privacy

1.2. ระดับความเสี่ยงโดยรวม

คะแนน	ระดับความเสี่ยง
0 – 3	ต่ำ
3 – 6	ปานกลาง
6 – 9	สูง

2. CVSS v3.1 Rating

คะแนน	ระดับความเสี่ยง
0.0	ไม่มีความเสี่ยง
0.1 – 3.9	ต่ำ
4.0 – 6.9	ปานกลาง
7.0 – 8.9	สูง
9.0 – 10.0	สูงมาก (Critical)